

HOME ASSIGNMENT

Compliance Coverage Agent Implementation Report

How a GDPR / EU AI Act / DPDP clause-retrieval agent — scraping, embedding, vector search, and LLM reranking — was designed, built, and merged into an existing Express + vanilla-JS chat application.

- ✓ Backend completed
- ✓ Backend tested with Postman
- ✓ Frontend completed
- ✓ Retrieval checked in frontend

Scope note: this report covers only the Compliance Coverage Agent (scraping → ingestion → vector search → reranking → UI) as merged into the host application. Accompanies

`Compliance_Agent.postman_collection.json` .

1. Overview

The Compliance Coverage Agent answers a different kind of question than a typical chatbot: given a user story or requirement, it returns the most relevant clauses from a legal/regulatory text — GDPR, the EU AI Act, or India's Digital Personal Data Protection Act (DPDP) 2023 — ranked by relevance, instead of a synthesized prose answer. It exists to let testers/analysts map a requirement to its compliance obligations directly.

The agent has three stages:

1. **Scraping** — fetch every article/section of a legal source directly from its public site and extract clean, structured clause text.
2. **Ingestion** — embed each clause's text into a vector (Mistral embeddings) and upsert it into MongoDB Atlas, idempotent by clause ID.
3. **Retrieval** — embed a user's story, run an Atlas `$vectorSearch` against the stored clauses, then rerank the candidates with an LLM for real relevance, and render the ranked result as a table in the chat UI.

Why a separate MongoDB cluster. Atlas caps how many search indexes a cluster/tier can hold. The application's existing vector store had already reached that cap, so the Compliance agent's three standards (GDPR, EU AI Act, DPDP) were provisioned in a second, dedicated Atlas cluster/account — each standard in its own collection with its own vector index, all reachable from the same running server at the same time.

2. Backend — Implementation

2.1 Component map

FILE	RESPONSIBILITY
<code>gdprScraper.js</code>	Fetches every GDPR article (Art. 1–99) directly by numeric URL; extracts clause ID, title, and body text via Cheerio.
<code>euAiActScraper.js</code>	Fetches every EU AI Act article (Art. 1–113) directly by numeric URL; same extraction shape.
<code>dpdpScraper.js</code>	Discovers every DPDP section's real URL from the source site's own navigation first (URLs nest under a non-guessable chapter prefix), then fetches all 44 sections.
<code>complianceIngest.js</code>	Shared ingestion core: embeds a batch of clauses (Mistral) and <code>bulkWrite</code> -upserts them into the given Mongo collection, keyed by <code>clauseId</code> .
<code>create-gdpr-embeddings.js</code> / <code>create-eu-ai-act-embeddings.js</code> / <code>create-dpdp-embeddings.js</code>	Thin per-standard CLI wrappers around the shared ingestion core.
<code>complianceClauseRetriever.js</code>	Shared retrieval core: embeds the user's story, runs <code>\$vectorSearch</code> , hands candidates to the reranker, returns ranked matches.
<code>complianceRerank.js</code>	Sends vector-search candidates to the chat model with a scoring prompt; parses back a 0–1 relevance score per candidate.
<code>gdprRetriever.js</code> / <code>euAiActRetriever.js</code> / <code>dpdpRetriever.js</code>	Thin per-standard instantiations of the shared retrieval core.
<code>dnsOverride.js</code>	Ensures DNS resolution for the Compliance cluster's <code>mongodb+srv://</code> connection works correctly on networks whose default resolver interferes with it.
<code>createComplianceIndexes.js</code>	One-time/idempotent script that creates or updates each standard's Atlas Vector Search index to the canonical definition.
<code>ingestionAdmin.js</code> additions	HTTP-facing wrappers around the scrape/embed core functions, plus a config-exposing endpoint for the frontend.

2.2 Data flow

```
Public legal-text site (gdpr-info.eu / artificialintelligenceact.eu / dpdpa.com)
→ fetch() raw HTML
→ Cheerio parses + extracts { standard, clauseId, title, text, url }
→ written to a local JSON checkpoint file
→ Mistral embeds each clause's "title\n text" as a 1024-number vector
→ MongoDB bulkWrite (upsert by clauseId) into a dedicated Compliance cluster
```

User story (typed in chat UI)

```
→ Mistral embeds the story as its own vector
→ Atlas $vectorSearch (cosine similarity) returns top-K candidate clauses
→ candidates sent to the chat model with a relevance-scoring prompt
→ matches re-sorted by score, nothing dropped, returned to the UI
```

2.3 Document schema (MongoDB)

```
{
  standard: "GDPR" | "EU AI Act" | "DPDP",
  clauseId: "Art. 17 GDPR",
  title: "Right to erasure ('right to be forgotten')",
  text: "The data subject shall have the right to obtain from the controller...",
  url: "https://gdpr-info.eu/art-17-gdpr/",
  embedding: [ /* 1024 numbers */ ],
  metadata: { standard: "GDPR", clauseId: "Art. 17 GDPR" },
  createdAt: ISODate, updatedAt: ISODate
}
```

The Atlas Vector Search index definition matches this shape exactly:

```
{ "fields": [
  { "type": "vector", "path": "embedding", "numDimensions": 1024, "similarity": "cosine" },
  { "type": "filter", "path": "metadata.standard" },
  { "type": "filter", "path": "metadata.clauseId" }
] }
```

2.4 API endpoints exposed

METHOD	PATH	PURPOSE
GET	/api/admin/ingest/compliance-config	Returns the live DB name + per-standard collection/index names, read from server config.
GET	/api/admin/ingest/files?source=compliance	Lists scraped clause JSON files ready to embed.
POST	/api/admin/ingest/scrape-compliance	Body { standard: "gdpr" "euai" "dpdp" } — scrapes that standard's source site.
POST	/api/admin/ingest/embed-compliance	Body { fileName, collectionName } — embeds + upserts a scraped file into Mongo.
POST	/api/knowledge/query	Body { source: "gdpr" "euaiact" "dpdp", query } — runs retrieval, returns ranked matches.

3. Backend — Tested with Postman

Every endpoint above was exercised with real HTTP requests against the running server (the exact requests are packaged in the accompanying `Compliance_Agent.postman_collection.json`, organized into **Ingestion** and **Retrieval** folders). Representative request/response pairs, captured live:

GET /api/admin/ingest/compliance-config

```
{
  "dbName": "Knowledge_base",
  "standards": {
    "gdpr": { "collectionName": "gdpr", "indexName": "gdpr_index" },
    "euai": { "collectionName": "euai", "indexName": "euai_index" },
    "dpdp": { "collectionName": "dpdp", "indexName": "dpdp_index" }
  }
}
```

POST /api/admin/ingest/embed-compliance

Request body:

```
{ "fileName": "gdpr-clauses.json", "collectionName": "gdpr" }
```

Response:

```
{ "inserted": 0, "updated": 99 }
```

(`inserted: 0`, `updated: 99` confirms the `upsert-by- clauseId` behavior — re-running ingestion against unchanged source text updates the existing 99 GDPR documents in place rather than duplicating them.)

POST /api/knowledge/query (source: gdpr)

Request body:

```
{ "source": "gdpr", "query": "User can request full deletion of their account and data" }
```

Response (top matches):

```
{
  "matches": [
    { "clauseId": "Art. 17 GDPR", "title": "Right to erasure ('right to be forgotten')", "score": 1.0,
      "url": "https://gdpr-info.eu/art-17-gdpr/" },
    { "clauseId": "Art. 19 GDPR", "title": "Notification obligation regarding rectification or erasure",
      "score": 0.7, "url": "https://gdpr-info.eu/art-19-gdpr/" }
  ]
}
```

Result: for a story about account/data deletion, the top-ranked clause is Art. 17 GDPR (Right to erasure) with a perfect relevance score of 1.0 — the reranking step is correctly distinguishing the directly relevant clause from a merely adjacent one (Art. 19, same rights area, scored lower).

4. Frontend — Implementation

4.1 Ingestion Wizard

The existing ingestion admin UI was extended with a card-based source selector: a **Compliance** card sits alongside the pre-existing source card. Selecting it swaps in three standard cards — **GDPR**, **EU AI Act**, **DPDP** — in place of the fields used by the other source, and relabels the action button to "Scrape Articles". A second step lists whichever standard's scraped files are on disk; selecting one auto-fills the destination collection name and shows the real (read-only) vector index name for that standard, sourced live from the server's config endpoint rather than hardcoded in the browser.

 **Ingestion**

✕ Close

STEP 1 · FETCH & CHUNK

**Confluence**
Test Plan / PRD / etc.

**Compliance**
GDPR / EU AI Act / DPDP

GDPR
Art. 1-99

EU AI Act
Art. 1-113

DPDP
Sec. 1-44

Scrapes every article/section directly by number — no page ID needed (Confluence Page ID only applies to the Confluence source above). One embedding per whole clause. Takes roughly 1-2 minutes (sequential requests, polite delay between each).

Scrape Articles

STEP 2 · AVAILABLE FILES

Refresh

gdpr-clauses.json196.6 KB · 16/08/2026, 17:33:03

STEP 3 · EMBED & STORE

Compliance cluster → database: Knowledge_base

gdpr

gdpr_index

Storing into a brand-new collection/index name always succeeds, but vector search against a new index won't work until that index is created in Atlas (a manual step, outside this app). For GDPR/EU AI Act/DPDP the index name shown is read-only (informational) - it's not needed to write documents, only chosen at query time, so it always reflects the real configured index.

Embed & Store →

The Ingestion Wizard captured live: Compliance source selected, GDPR standard selected, a previously-scraped file listed in Step 2, and Step 3 auto-filled with the real destination — collection `gdpr`, index `gdpr_index`, database `Knowledge_base` — all read from the server's live config, not hardcoded in the browser.

4.2 Knowledge Search source selector

The chat UI's Knowledge Search dropdown gained three new options — **GDPR**, **EU AI Act**, **DPDP** — each routed straight to `/api/knowledge/query` with the corresponding `source` value. Typing a user story and selecting one of these sources (instead of the pre-existing source) triggers Compliance retrieval rather than a synthesized chat answer.

4.3 Compliance Matches table

Because retrieval already returns fully structured data (clause ID, title, score, URL, excerpt text) rather than free-form LLM markdown, the frontend renders it as a real table instead of parsing text: **Clause / Relevance** (color-tiered badge) / **Excerpt** (scrollable text box) / **Link** to the source article, with a header showing the match count and a "Copy matches" action.

5. Retrieval — Checked in Frontend

Both screenshots below were captured directly from the running application's chat UI, driven through the real Knowledge Search flow (select source → type story → Search), not simulated.

GDPR — "User can request full deletion of their account and data"

Compliance Matches 10 matches			Copy matches
CLAUSE	RELEVANCE	EXCERPT	
Art. 17 GDPR Right to erasure ('right to be forgotten')	1.00	The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without undue delay and the controller shall have the obligation to erase personal data without undue delay where one of the following grounds applies: the personal data are no longer necessary in relation to the purposes for which they were collected or otherwise processed; the data subject withdraws consent on which the processing is based according to point (a) of Article 6(1), or point (a) of Article	View →
Art. 19 GDPR Notification obligation regarding rectification or erasure of personal data or restriction of processing	0.70	The controller shall communicate any rectification or erasure of personal data or restriction of processing carried out in accordance with Article 16, Article 17(1) and Article 18 to each recipient to whom the personal data have been disclosed, unless this proves impossible or involves disproportionate effort. The controller shall inform the data subject about those recipients if the data subject requests it.	View →
Art. 12 GDPR Transparent information, communication and modalities for the exercise of the rights of the data subject	0.40	The controller shall take appropriate measures to provide any information referred to in Articles 13 and 14 and any communication under Articles 15 to 22 and 34 relating to processing to the data subject in a concise, transparent, intelligible and easily accessible form, using clear and plain language, in particular for any information addressed specifically to a child. The information shall be provided in writing, or by other means, including, where appropriate, by electronic means. When requested by the data subject, the information may be provided orally, provided that the identity of the data subject is proven by other means.	View →
Art. 25 GDPR Data protection by design and by default	0.30	Taking into account the state of the art, the cost of implementation and the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for rights and freedoms of natural persons posed by the processing, the controller shall, both at the time of the determination of the means for processing and at the time of the processing itself, implement appropriate technical and organisational measures, such as pseudonymisation, which are designed to implement data-protection principles, such as data minimisation, in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation	View →
Art. 11 GDPR Processing which does not require identification	0.20	If the purposes for which a controller processes personal data do not or do no longer require the identification of a data subject by the controller, the controller shall not be obliged to maintain, acquire or process additional information in order to identify the data subject for the sole purpose of complying with this Regulation. Where, in cases referred to in paragraph 1 of this Article, the controller is able to demonstrate that it is not in a position to identify the data subject, the controller shall inform the data subject accordingly, if possible. In such cases, Articles 15 to 20	View →

Top 5 of 10 ranked matches shown for the GDPR source (full result set scrolls in the live UI). Art. 17 (Right to erasure) correctly ranks first at 1.00, with adjacent-but-less-relevant articles (Art. 19, Art. 12, Art. 25, Art. 11) trailing behind by score rather than being omitted.

EU AI Act — "We want to deploy a facial recognition system for law enforcement in public spaces"

Compliance Matches 10 matches			Copy matches
CLAUSE	RELEVANCE	EXCERPT	
Article 27 Fundamental Rights Impact Assessment for High-Risk AI Systems	0.90	1. Prior to deploying a high-risk AI system referred to in Article 6(2), with the exception of high-risk AI systems intended to be used in the area listed in point 2 of Annex III, deployers that are bodies governed by public law, or are private entities providing public services, and deployers of high-risk AI systems referred to in points 5 (b) and (c) of Annex III, shall perform an assessment of the impact on fundamental rights that the use of such system may produce. For that purpose, deployers shall perform an assessment consisting of: (a) a description of the deployer's processes in which the high-risk	View →
Article 26 Obligations of Deployers of High- Risk AI Systems	0.70	1. Deployers of high-risk AI systems shall take appropriate technical and organisational measures to ensure they use such systems in accordance with the instructions for use accompanying the systems, pursuant to paragraphs 3 and 6. 2. Deployers shall assign human oversight to natural persons who have the necessary competence, training and authority, as well as the necessary support. 3. The obligations set out in paragraphs 1 and 2, are without prejudice to other deployer obligations under Union or national law	View →
Article 14 Human Oversight	0.70	1. High-risk AI systems shall be designed and developed in such a way, including with appropriate human-machine interface tools, that they can be effectively overseen by natural persons during the period in which they are in use. 2. Human oversight shall aim to prevent or minimise the risks to health, safety or fundamental rights that may emerge when a high-risk AI system is used in accordance with its intended purpose or under conditions of reasonably foreseeable misuse, in particular where such risks persist despite the application of other requirements set out in this Section.	View →
Article 82 Compliant AI Systems Which Present a Risk	0.60	1. Where, having performed an evaluation under Article 79, after consulting the relevant national public authority referred to in Article 77(1), the market surveillance authority of a Member State finds that although a high-risk AI system complies with this Regulation, it nevertheless presents a risk to the health or safety of persons, to fundamental rights, or to other aspects of public interest protection, it shall require the relevant operator to take all appropriate measures to ensure that the AI system concerned, when placed on the market or put into service, no longer presents that risk without undue delay, within a period it may prescribe.	View →
Article 77 Powers of Authorities Protecting Fundamental Rights	0.50	1. National public authorities or bodies which supervise or enforce the respect of obligations under Union law protecting fundamental rights, including the right to non-discrimination, in relation to the use of high-risk AI systems referred to in Annex III shall have the power to request and access any documentation created or maintained under this Regulation in accessible language and format when access to that documentation is necessary for effectively fulfilling their mandates within the limits of their jurisdiction. The relevant public authority or body shall inform the market surveillance authority of the Member State concerned of any such request.	View →

Top 5 of 10 ranked matches shown for the EU AI Act source. Article 27 (Fundamental Rights Impact Assessment for High-Risk AI Systems) ranks first at 0.90, with Article 26 (Deployer obligations) and Article 14 (Human Oversight) close behind — a sensible obligation set for this exact scenario.